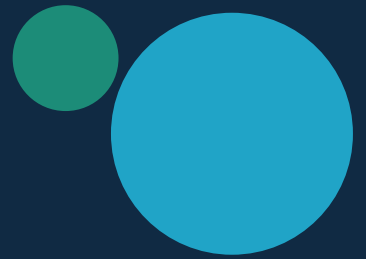


TIRGEO



Backend Architecture

Frontend integration guide

Detailed implementation and workflow contract

FOR FRONTEND DEVELOPERS AND TECHNICAL DELIVERY TEAMS

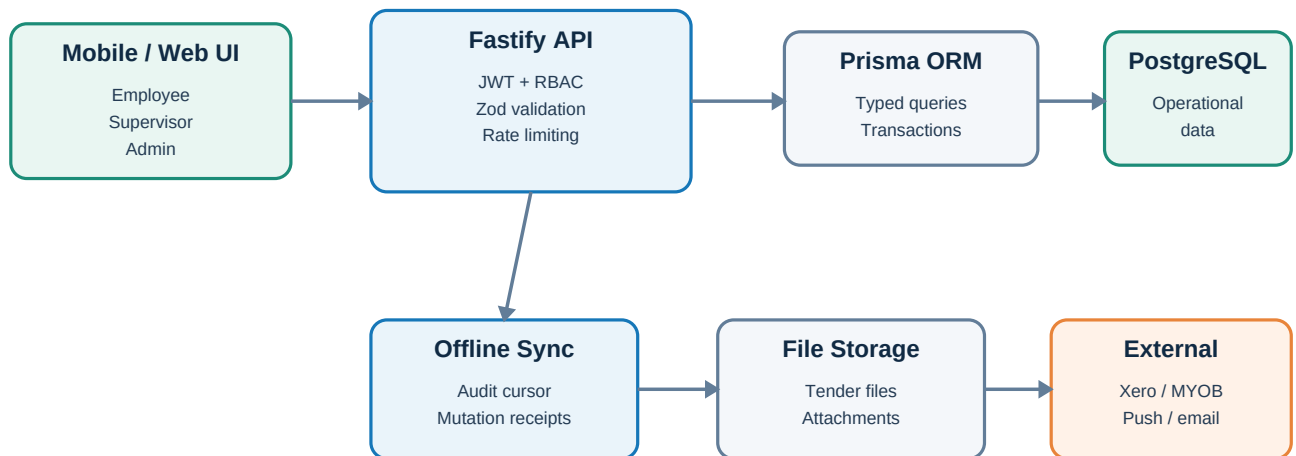
Architecture snapshot - 3 July 2026

1. Purpose and implementation status

This guide is the frontend integration contract for the current TirGeo backend. It maps screens and client state to implemented Fastify routes, Prisma records, workflow transitions, and external-system boundaries.

Current status: The backend compiles, lints, has a checked-in initial migration, Docker/CI release assets, and 20 focused workflow tests. Production delivery still requires PostgreSQL-backed API tests, broader read/admin endpoints, durable background jobs and object storage, refresh-token strategy, push transport, atomic offline mutation replay, and live Xero/MYOB OAuth connectors.

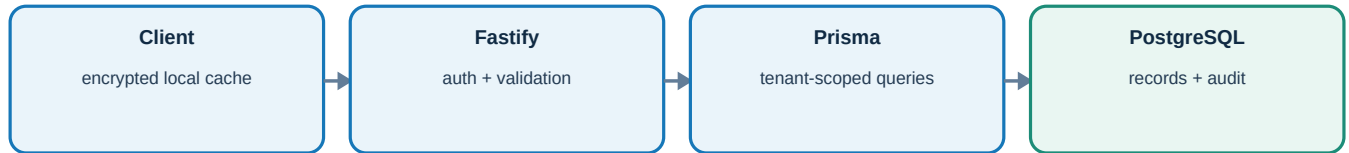
Current backend wiring and integration boundaries



Layer	Technology	Frontend implication
API	Fastify 5 / TypeScript	JSON REST under /api/v1; multipart for tender uploads
Identity	JWT with issuer/audience; active user rechecked	Store securely; attach Authorization: Bearer; handle 401/403 globally
Validation	Zod + database constraints	400 responses may include validation details
Data	PostgreSQL via Prisma migrations	UUID identifiers; dates are ISO-8601; decimals may serialize as strings
Evidence	SHA-256 hashes + audit events	Signed records should be treated as immutable in the UI
Delivery	Node 22, Docker and CI	Use readiness at /ready; deploy migrations before application rollout

2. System context and trust boundaries

A single deployment serves one civil contractor organisation. Every authenticated token carries `userId`, `organisationId` and `role`. Organisation scoping is the primary tenant boundary; role checks control privileged actions.



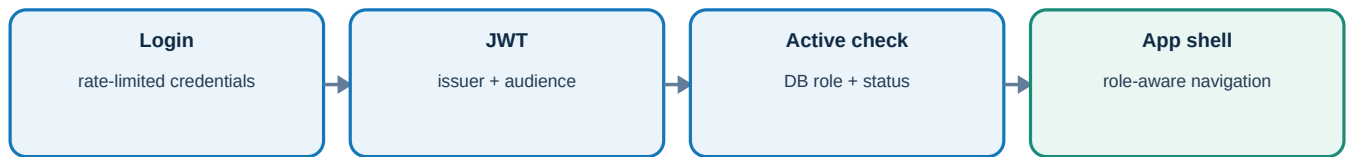
Trust boundaries

- The client may be offline and must never assume a network acknowledgement until the response is persisted locally.
- Employee and supervisor signatures are evidence records. Never re-use a signature image automatically or imply that selecting a name constitutes signing.
- The four-digit signing PIN verifies shared-device countersigning. The API rate-limits attempts and never returns the hash.
- Tender extraction is assistive. Requirements remain SUGGESTED until a manager confirms or rejects them.
- Payroll exports stage approved data; Xero/MYOB remain responsible for payroll calculations, tax, superannuation and STP.

Roles

Role	Typical frontend capability
OWNER / ADMIN	Organisation configuration, projects, payroll, commercial, safety approvals
PROJECT_MANAGER	Projects, timesheet approvals, tenders, claims, variations
SUPERVISOR / FOREMAN	Operational approval and shared-device countersigning
SAFETY_MANAGER	Approve and publish safety documents
PAYROLL	Configure mappings and stage payroll exports
WORKER / SUBCONTRACTOR	Own timesheets, assigned safety evidence, field records
CLIENT_AUDITOR	Read-only experience is intended but not yet fully routed

3. Authentication, session and signing PIN



Operation	Endpoint	Client behaviour
Login	POST /api/v1/auth/login	Persist token securely. Response includes user and signaturePinRequired.
Set first PIN	PUT /api/v1/auth/signature-pin	Send exactly four digits. Show after first login when required.
Change PIN	PUT /api/v1/auth/signature-pin	Send pin plus currentPin. Never log, cache or display either.
Shared-phone verify	POST /timesheets/:id/onsite-approve	Five failed PIN checks trigger a 15-minute account lock.
Logout	Client-side currently	Delete token and sensitive cached identity data.

Global response handling

- 401: credentials or signing verification failed; do not reveal which credential component was wrong.
- 403: authenticated but role is not permitted; hide or disable the action, but still handle server denial.
- 409: workflow conflict, duplicate, stale signature hash, or invalid transition; refresh the resource before retrying.
- 422: semantically incomplete request, such as a worker missing a payroll mapping.
- 429: rate limit, especially signing PIN attempts; display a calm retry message and do not loop automatically.
- 500: unexpected server failure; retain the local draft and expose a retry path.

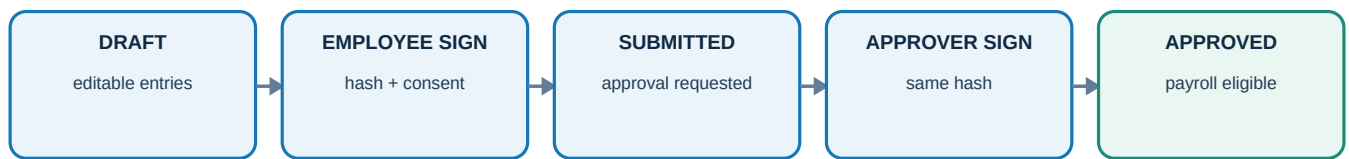
4. Recommended frontend information architecture

Area	Primary screens	Core records
Home	My actions, notifications, due safety items, draft timecards	Notification, SafetyAssignment, Timesheet
Projects	Project list/detail, cost codes, daily report	Project, CostCode, DailyReport
Time	Create/edit card, employee sign, supervisor approval inbox, payroll status	Timesheet, TimeEntry, signatures, approval request
Safety	Document library, publish/assign, my acknowledgements, incidents	SafetyDocument, Assignment, Acknowledgement, Incident
Plant	Asset list/detail, template builder, pre-start form, defects	Plant, PreStartTemplate, PlantPreStart
Commercial	Tender workspace, requirements, checklist, claims, variations	Tender, TenderDocument, Requirement, ChecklistItem
Payroll	Provider configuration, worker mappings, export batches	AccountingConnection, mappings, PayrollExport
Settings	Profile, signing PIN, devices, organisation	User, Device, Organisation

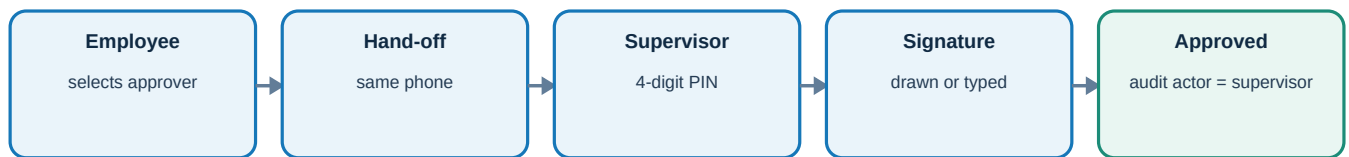
Navigation rules

- Drive navigation from role and actual API capability, not role labels alone.
- Separate “My work” from management views: own signatures and assignments need fewer controls and stronger task focus.
- Show explicit workflow status chips and next actions. Do not infer status solely from timestamps.
- Use optimistic UI only for drafts. Signed, approved, exported and reconciled states should wait for the server response.

5. Signed timecard lifecycle



Shared-phone path



Screen/action	API	Required UI constraints
Approver picker	GET /timesheets/approvers	Only server-returned eligible users; exclude employee.
Create card	POST /timesheets	Capture project, worker, week ending and one or more entries.
Employee submit	POST /timesheets/:id/submit	Capture approverUserId, signedName, signature, method and consent=true.
Remote approval	POST /timesheets/:id/approve	Selected approver must be logged in; capture their signature.
On-site approval	POST /timesheets/:id/onsite-approve	Employee session remains open; supervisor supplies user, PIN and signature.
Reject	POST /timesheets/:id/reject	Require reason; show correction path as product work still to define.

Integrity rule: submission hashes the exact card and entries. Approval recalculates the hash and fails with 409 if anything changed. The frontend must render the signed snapshot and prevent editing after submission.

6. Safety document and toolbox-talk lifecycle

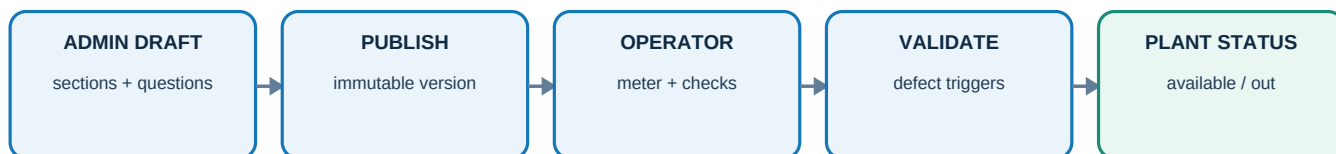


Action	Endpoint	Frontend requirement
Create	POST /safety/documents	Select supported type and structured activities, hazards and controls.
Approve	POST /safety/documents/:id/approve	Safety approver action; hash is created here.
Publish	POST /safety/documents/:id/publish	Select organisation workers and optional due date.
My assignments	GET /safety/my-assignments	Task list with document and existing acknowledgement.
Sign	POST /safety/documents/:id/acknowledge	Only linked worker can sign; signedName, signature, method, consent=true.
Incident	POST /safety/incidents	Capture project, occurrence time, severity, narrative and immediate actions.

Evidence displayed to users

- Document title, type, version and approval status.
- The exact content presented at signing; contentHash should be retained in frontend audit views.
- Signer name, timestamp, signature method and consent statement.
- Due state and completion state for each assignment.

7. Configurable plant pre-starts



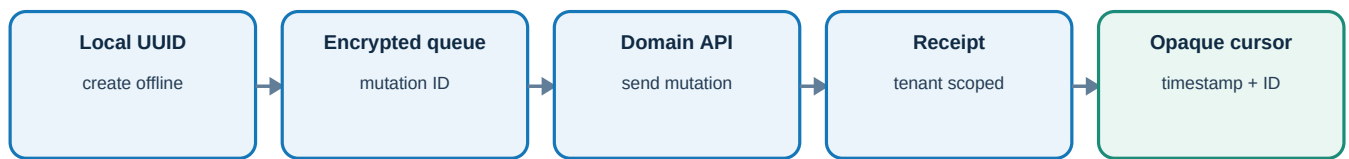
Surface/action	Endpoint	Frontend rule
Published templates	GET /plant/pre-start-templates?plantType=	Show generic and matching plant-type templates; prefer the most specific published version.
Admin template list	GET /plant/pre-start-templates/manage	Owner/admin only; display DRAFT and PUBLISHED distinctly.
Create next version	POST /plant/pre-start-templates	Question IDs must be stable and unique; types: PASS_FAIL_NA, BOOLEAN, TEXT, NUMBER.
Edit draft	PATCH /plant/pre-start-templates/:id	Published versions are immutable. Create a new version for changes.
Publish	POST /plant/pre-start-templates/:id/publish	Confirm before publishing because inspections bind to this version.
Complete pre-start	POST /plant/:id/pre-starts	Send template ID, readings, answers, result, defects and operator signature.

Out-of-box generic checklist

- Engine-off checks: fluids/leaks, tyres or tracks, guards/panels, attachments, access/egress and safety equipment.
- Engine-on checks: restraints, instruments, alarms/lighting, communications and controls.
- Fault section: defect notes plus explicit lock-out/tag-out confirmation.
- A configured defect-trigger answer cannot produce PASS. OUT_OF_SERVICE updates the asset immediately; all submissions update meter readings.

Template UI: use a section-and-question builder with stable machine IDs, human labels, guidance, required toggles and “defect when” values. Preview the exact operator form before publication.

8. Offline and synchronisation model



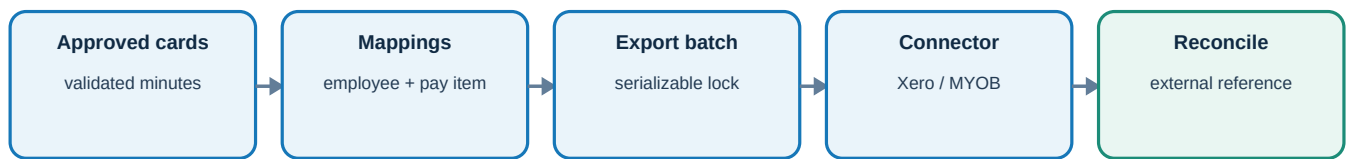
Endpoint	Purpose	Client rule
POST /sync/register	Register tenant/user-owned device metadata	Use a stable device UUID. Revoked devices and cross-user registration are rejected.
GET /sync/pull?deviceId=&cursor;=&limit;=	Fetch ordered, redacted change metadata	Continue until hasMore=false; treat the composite cursor as opaque and store it verbatim.
POST /sync/receipt	Record organisation-scoped mutation receipt	Device must belong to the current user and must not be revoked.

Current limitation: receipts are tenant-safe, but domain writes do not yet create their receipt inside the same transaction. Do not market or implement exactly-once offline writes until mutation IDs are bound atomically to each domain operation.

Conflict guidance

- Approved timesheets and signed safety acknowledgements are append/correct, never last-write-wins.
- Draft daily reports may use field-level merge after product rules are defined.
- Plant OUT_OF_SERVICE wins over availability until authorised clearance exists.
- Uploads should be retried separately after the parent record is confirmed.

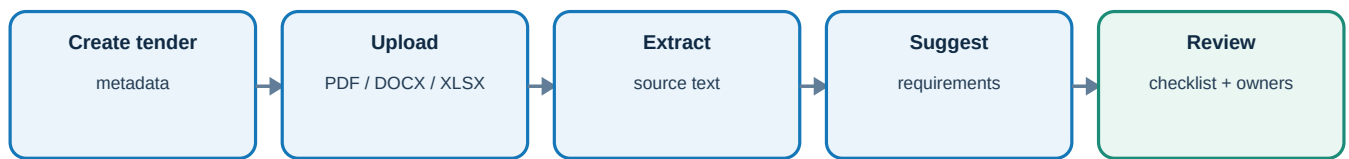
9. Payroll integration workflow



Operation	Endpoint	Status/constraint
Configure metadata	PUT /payroll/connections/:provider	Creates CONFIGURED metadata only; it does not imply live OAuth.
Map employee	PUT /payroll/connections/:provider/employees/:workerId	Required before worker cards can enter an export.
Map pay item	PUT /payroll/connections/:provider/pay-items/:localCode	Stores provider pay-item identifiers for connector translation.
Create export	POST /payroll/exports	Approved cards must fall in period and not belong to a non-failed export; failed batches may be retried.
Record delivery	PATCH /payroll/exports/:id/status	Sent/reconciled requires external reference; failed requires reason.

Not yet live: OAuth, secret storage, outbound provider calls, webhooks and automatic reconciliation remain connector work. Present current exports as staged batches, not completed payroll payments.

10. Tender workspace and extraction flow



Frontend surface	API behaviour
Tender workspace	GET /commercial/tenders/:id returns documents, requirements and checklist items.
Document uploader	POST multipart file to /commercial/tenders/:id/documents; one file, maximum 25 MB.
Processing state	PENDING / PROCESSING / REVIEW_REQUIRED / NO_REQUIREMENTS_FOUND / FAILED.
Requirement review	PATCH requirement with CONFIRMED or REJECTED and optional corrected text/mandatory flag.
Checklist board	PATCH item status, ownerId and dueAt. Status: TODO, IN_PROGRESS, COMPLETE, NOT_APPLICABLE.
Traceability	Show source document plus sourcePage or sourceSheet and sourceExcerpt beside each suggestion.

Analysis boundary: extraction is deterministic keyword-assisted analysis, not a legal interpretation engine. The UI must call results “suggestions,” expose confidence/source, and require human confirmation.

11. Implemented endpoint catalogue

Domain	Routes (under /api/v1)	Purpose
Auth	POST /auth/login; PUT /auth/signature-pin	Rate-limited login and shared-device signing setup
Projects	GET/POST /projects; PATCH /projects/:id/status	Validated project lifecycle
Time	GET /timesheets/approvers; POST /timesheets	Approver picker and payroll-grade card validation
Time	POST /timesheets/:id/submit approve onsite-approve reject correct	Signed approval and immutable correction revisions
Safety	POST /safety/documents; approve; publish; acknowledge	Versioned safety evidence
Safety	GET /safety/my-assignments; POST /safety/incidents	Worker tasks and tenant-scoped incident capture
Plant	GET/POST /plant; POST /plant/:id/pre-starts clearance	Validated inspections and authorised return to service
Plant	GET/POST/PATCH /plant/pre-start-templates; publish	Versioned admin-configurable checklists
Field	POST /field/daily-reports	Tenant-scoped daily delivery capture
Commercial	POST /commercial/tenders; GET /tenders/:id	Tender creation and workspace
Commercial	POST tender documents; PATCH requirement/checklist	Validated tender extraction and consistent review
Commercial	POST /progress-claims; POST /variations	Tenant-scoped commercial records
Payroll	PUT connection/employee/pay-item mappings; POST exports; PATCH status	Retryable staged accounting integration
Sync	register; pull; receipt	Tenant-scoped devices, redacted events and opaque cursors
Notifications	GET /notifications; POST /:id/read	In-app approval inbox

Missing read/update surfaces to plan with backend

- Worker directory and worker profile CRUD.
- Timesheet list/detail endpoints and explicit correction/resubmission lifecycle.
- Safety document list/detail and management reporting.
- Plant detail/history and authorised return-to-service flow.
- Daily report retrieval/editing, project cost-code CRUD and document download URLs.
- Tender list and file download/delete/reprocess endpoints.
- Payroll export list/detail and connector health endpoints.
- Refresh tokens, password reset, account provisioning and device revocation.

12. Data shapes and client conventions

Convention	Guidance
Identifiers	UUID strings. Generate locally only where offline contract explicitly allows it; many current create routes generate server IDs.
Dates	Send ISO-8601. Treat organisation timezone as Australia/Sydney unless returned otherwise. Distinguish date-only work dates from instants.
Money / decimals	Prisma Decimal values may arrive as JSON strings. Parse with decimal-safe utilities; never binary floating point for totals.
Enums	Render labels from server enum values; preserve unknown values for forward compatibility.
JSON fields	Several early models use flexible JSON arrays/objects. Validate client-side but retain raw server values.
Signatures	Currently strings: use a documented image encoding or object-storage reference. Avoid oversized base64 payloads in local logs.
Errors	Standard shape is generally { error: string }, with optional details or workerIds.
Pagination	Only sync has cursor/limit today. Plan reusable cursor pagination for future lists.

Suggested client modules

- apiClient: token injection, redaction-safe logging, error normalization and retry policy.
- sessionStore: user, role, organisation and signaturePinRequired; no PIN persistence.
- syncEngine: encrypted mutation queue, cursor checkpointing and conflict handlers.
- evidenceCapture: signature pad, consent rendering and immutable snapshot review.
- uploadManager: file validation, resumable state and processing-status polling.
- domain stores: projects, time, safety, plant, commercial, payroll and notifications.

13. Security, privacy and production readiness

Control	Current backend	Frontend responsibility
Transport	Assumes deployment TLS	Refuse non-TLS production API URLs.
JWT	Issuer/audience validated; active user and current role rechecked	Secure storage; clear on logout/401; refresh strategy pending.
Passwords/PINs	bcrypt, log redaction, route limits and account PIN lock	Never persist PIN; disable autofill; prevent shoulder-surfing where practical.
Tenant isolation	Central project checks plus organisation-scoped sync identities	Never trust client-selected organisation IDs.
Audit	Sensitive evidence workflows audit inside their transactions	Provide readable audit surfaces; do not edit evidence locally.
Files	Magic validation and extraction limits; local storage	Object storage and malware scanning remain production infrastructure work.
Delivery	Migration, Dockerfile, CI, /health and DB-backed /ready	Treat /ready failure as unavailable; do not send traffic.
CORS/proxy	Origins configurable; proxy trust disabled by default	Set exact production origins and enable proxy trust only behind known infrastructure.

Frontend release gate

- Apply the checked-in migration against a disposable environment and run database-backed tenant/API tests.
- Change the seeded password and provide managed JWT/database secrets.
- End-to-end test employee sign, shared-phone PIN lockout/sign, remote approval, correction and export retry.
- Accessibility test signature canvas, status, template builder, forms and offline errors.
- Threat review token storage, tender uploads, signatures, object storage and integration credentials.
- Feature-flag live payroll connectors, push delivery and exactly-once offline writes until their infrastructure is complete.

14. Frontend delivery sequence

Phase	Build	Backend dependency
1. Shell and identity	Login, role navigation, API client, error system, signing-PIN setup	Existing auth routes
2. Core field work	Projects, plant register, template builder, pre-start and daily report forms	Add missing detail/history endpoints as required
3. Signed time	Timecard editor, signature capture, approval inbox, shared-phone handoff	Add list/detail and correction lifecycle
4. Safety evidence	My assignments, document viewer, signing and management publish flow	Add safety list/detail and evidence report
5. Commercial	Tender upload/review/checklist, variations and claims	Add tender list/download and commercial reads
6. Payroll	Mappings and staged export status	Implement OAuth connector service before "sync" claims
7. Offline hardening	Encrypted cache, mutation queue, conflict UX	Bind mutation IDs directly to writes

Design principle: The app should feel like one job-site workflow, not a set of administrative modules. "What do I need to do now?" is the primary employee experience; project, compliance and commercial records are the evidence underneath.

End of frontend architecture guide